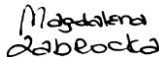


TECHNICAL SECURITY SPECIFICATIONS FOR WEB IIS

AUTHOR(S) : Thomas Le Pivaing, Wojciech Brzezinski, Oliver Plewa, Manoj Kumar Prabhanjan N
DOCUMENT NUMBER : MSP-GAD-0236
VERSION : 7.0
STATUS : Final
SOURCE : Atos
DOCUMENT DATE : 26 April 2021
NUMBER OF PAGES : 24

OWNER : Manoj Kumar Prabhanjan N

Role	Signature
Document Owner	29-04-2021 X  N, Manoj Kumar Prabhanjan Global Service Architect Signed by: Manoj Kumar Prabhanjan N
Reviewer	04/05/2021 X  Magdalena Zabrocka Global Operation Security Compliance Officer Signed by: Magdalena Zabrocka
Quality Assurance Function	09-05-2021 X Approved Santosh Kudtarkar Documentation Controller Signed by: Santosh Kudtarkar
Senior Manager	09-05-2021 X  Dorin Vlas Head of Risk Management and Control Fra... Signed by: Santosh Kudtarkar

Contents

1	General Information	7
1.1	Purpose	7
1.2	Audience	7
1.3	Scope	7
1.4	Implementation of measures	7
1.5	Document maintenance and distribution.....	8
1.6	Related documents.....	8
2	Introduction	9
2.1	Risk Classifications	9
2.2	Deviations	9
3	Description of Measures	10
3.1	Basic Security Rules	10
3.2	Configuration.....	11
3.3	Authentication and authorization	12
3.4	Transport Layer Security (TLS/SSL).....	12
3.5	Modules and features.....	17
3.6	Additional Security measures.....	18
3.7	Secure Administration.....	20
4	Non-Alcatraz measures	22
4.1	Webserver related measures	22
Appendix A	Checklist	24

List of changes

version	Date	Description	Author(s)
0.1	2014-03-14	Initial version	Thomas Le Pivaing
0.2	31-03-2014	Changed measure tables	Patrick Holt
1.0	19-05-2014	Final version	Patrick Holt
1.1	01-10-2014	Update of the implementation sections	Thomas Le Pivaing
1.2	17-12-2014	Added variable field to measures	Patrick Holt
1.3	27-01-2015	Changed variable field into exception field	Patrick Holt
1.4	02-02-2015	Changed Senior Manager Atos name to David Bixler	Patrick Holt
1.5	23-03-2015	Corrected some grammar errors	Patrick Holt
2.0	24-03-2015	Final version	Patrick Holt
2.1	09-04-2015	Added measure #00017, #00018, #00019, #00020 Updated checklist	Thomas Le Pivaing
2.2	09-04-2015	Changed measures #00010, #00011, #00012, SSL and TLS	Thomas Le Pivaing
2.3	21-09-2015	Removed signature line for Global Tower Head	Patrick Holt
2.4	21-09-2015	Added extra text to section 1.4: "All exceptions to measures mandated by this document must be registered in the Atos Risk Tool (ART) and must be agreed by the Client Security Manager and the Customer."	Patrick Holt
2.5	13-10-2015	Added extra section "Document maintenance and distribution" Removed all references to MSM-GSS-0008 Changed GSS to BDS in the whole document	Patrick Holt
3.0	09-11-2015	Final version	Patrick Holt
3.1	21-02-2018	Reworked every measure Restructured document Increased priority of #00010 to CRITICAL Added new measures #00021, #00022, #00023, #00024, #00025, #00026, #00027	Oliver Plewa
3.2	23-02-2018	Added protect information to #00023	Oliver Plewa
4.0	02-03-2018	Final Version	Oliver Plewa
4.1	26-06-2018	Add information for automated scan tooling	Oliver Plewa
4.2	22-01-2020	Increased priority of #00019 to CRITICAL Modified #00019, #00021 Added #00028	Oliver Plewa
4.3	27-01-2020	Minor updates (template, typo errors, approval table), Modified #00019, Abbreviations table	Wojciech Brzezinski
4.4	03-02-2020	Security review, Senior Manager change Checklist update	M. Zabrocka
4.5	03-02-2020	Update due to EOSL IIS 7.0 and 7.5, added SHA-2, other minor updates.	Wojciech Brzezinski
4.6	04-02-2020	Chapter 4 title change,	Z. Zabrocka

version	Date	Description	Author(s)
		Checklist update	
4.7	15-02-2020	Remarks, exception update for WI00019 & WI00021	Wojciech Brzeziński
5.0	17-02-2020	Final Version	Wojciech Brzezinski
5.1	26-03-2020	Added exceptions for IIS for Sharepoint services in WI00026, WI00015 and WI00025; policy value updated for WI00025	Wojciech Brzezinski
5.2	10-04-2020	Typo correction in WI00012 Security review	M. Zabrocka
5.3	3-06-2020	Alcatraz Review	Pechholz, Henrik
6.0	3-06-2020	Final	W. Brzeziński
6.1	05-11-2020	Reviewed the Classification. Measure ID prefix restored	Manoj, N.
6.2	19-01-2021	Alcatraz scanner implementation review	Henrik Pechholz
6.3	19-01-2021	Corrections after GOSCO review: - Measures 2WI00015, 2WI00024, 2WI00025, 2WI00026 and 2WI00027 moved to chapter 3.6 Additional measures from non-Alcaraz measures (Chapter 4) - removed unsupported versions	Manoj, N.
6.4	29-01-2021	Security Review	M. Zabrocka
6.5	12-04-2021	Updated 2WI00028	Manoj, N.
6.6	13-04-2021	Alcatraz scripts confirmed by Henrik	M. Zabrocka
6.7	13-04-2021	Security review	M. Zabrocka
6.8	26-04-2021	Updated measure WI00026	Manoj, N
7.0	26-04-2021	Modified according to new template	Manoj, N
		Quality Assurance	Santosh Kudtarkar

Target readers, communication method

Target group	Distribution / publication method
Designers	SharePoint
Architects	SharePoint
Administrators	SharePoint

Terms and abbreviations

Terms and definitions are described in [Terms and Abbreviation List](#)

Terms / Abbreviations	Description
IIS	Internet Information Services
MSADC	Microsoft Active Directory Connector
NTFS	New Technology File System
SSL	Secure Socket Layer
TLS	Transport Layer Security
RSA	Rivest, Shamir, Adleman
DSA	Digital Signature Algorithm
ECDSA	Elliptical Curve Digital Signature Algorithm
HTTPS	Hyper Text Transfer Protocol Secure
FTP	File Transfer Protocol
MIME	Multi-purpose Internet Mail Extensions
XSS	Cross-site Scripting
MD5	Message Digest Algorithm 5
SHA	Secure Hash Algorithm
DES	Data Encryption Standard

1 General Information

1.1 Purpose

A Technical Security Specification (TSS) is a document that translates the high-level security controls contained in the Atos IDM Security Baselines into specific Technical Security Measures.

Each TSS documents the Technical Security Measures for the configuration of a specific device, application or operating system. These Measure are then validated for compliance using specifically-developed scripts. That data is then used to generate compliance reports, and to drive remediation of deficiencies.

The document also details the Risk Classification, the data and data sources required for each Technical Security Measure.

1.2 Audience

This document is intended for designers, architects and administrators tasked with validation and implementation of the security baselines as per IT Control Framework (ITCF).

The document assumes that the reader has reasonable understanding of the Security Compliance Process as well as familiarity with the devices/software mentioned in this document.

1.3 Scope

The scope of this Technical Security Specification covers the following:

- ▶ IIS Versions 8.0, 8.5, 10
- ▶ Basic IIS Security
- ▶ IIS configuration
- ▶ Authentication and Authorization
- ▶ Modules and features
- ▶ Secure Administration

The following areas are explicitly out of scope:

- ▶ IIS Versions 5.0, 6.0, 7.0, 7.5
- ▶ Server Security
- ▶ Database Security

1.4 Implementation of measures

The implementation of the TSS measures is mandatory for all target devices and software mentioned in the scope. In case of implementation in existing environments, TSS measures must be tested first in pre-production test environments following applicable change management processes before implementation in production.

Some of the measures in this document may affect compliance to industry specific regulations. In this case the security officer must approve the implementation or create an exception.



All exceptions to measures mandated by this document must be registered in the Atos Risk Tool (ART) and must be agreed by the Client Security Manager and the Customer.

1.5 Document maintenance and distribution

The TSS document, when approved, published and validated, becomes procedural to all referenced systems, services, applications or processes managed by Atos Infrastructure & Data Management (I&DM) following a 120 days grace period, during which an analysis of gaps, documentation of exceptions, and a plan to bring non-compliant systems into compliance must be developed.

The maintenance of the document is performed by the Global Service Architect. TSS documents will be reviewed minimally on an annual basis, unless technical or business requirements dictate updating sooner.

1.6 Related documents

This document is a subset of Atos Technology Lifecycle Management (ATLM) artifacts. Related documents are captured in below table.

Reference	Document Name
MSM-GSS-0001	Security Management Baseline
MSM-GSS-0002	Logical Security Baseline
MSM-GSS-0013	TECHNICAL SECURITY SPECIFICATION (TSS) CREATION PROCESS
MSM-GSS-005	Middleware Security Baseline

Table 1: ATLM Related Documents

A number of vendor best practice documentation has been used in this TSS as per next table.

Vendor	Document Name
Microsoft	https://docs.microsoft.com/en-us/iis/
Microsoft	https://docs.microsoft.com/en-us/windows/win32/secauthn/cipher-suites-in-schannel
Microsoft	https://docs.microsoft.com/en-us/windows/win32/secauthn/protocols-in-tls-ssl--schannel-ssp-
Microsoft	https://docs.microsoft.com/en-us/windows-server/security/tls/tls-registry-settings#keyexchangealgorithm---diffie-hellman-key-sizes
Microsoft	https://docs.microsoft.com/en-us/iis/manage/provisioning-and-managing-iis/configure-logging-in-iis
Microsoft	https://support.microsoft.com/en-us/lifecycle/search?alpha=Microsoft%20Internet%20Information%20Services

Table 2: Vendor documentation

2 Introduction

The "TECHNICAL SECURITY SPECIFICATIONS FOR WEB IIS" is a mandatory supplement to the existing Atos Security Policy and IT Security Controls. Its purpose is to increase security for IT systems and it must be implemented for all Atos managed devices. The measures and their priorities described here may be tightened and supplemented as necessary.

The TSS documents are published by Atos Risk, Audit & Compliance Governance (RACG). The TSS itself is coordinated with reviewers from the Global Security Services and all relevant Atos Global Delivery units. It aims at providing sufficient detail to allow a qualified administrator to implement all measures.

To assist in documentation, a checklist for the manual validation process has been prepared as part of this TSS in appendix A.

Further assurance about the compliance of a device or software to the Atos IT Security Controls can be gained via a Scan on Demand as part of the Vulnerability Management Service offered Atos Big Data & Security (BD&S).

2.1 Risk Classifications

Each confirmed measure is assigned a risk level (Critical, Moderate, or Low) corresponding to its potential impact on the security of Atos service delivery and devices/software in scope.

CRITICAL

A security control is critical if it can be exploited by a remote attacker to gain access to the system, data or functionality when not implemented. All critical controls must be implemented before the equipment is installed in a production environment.

MODERATE

A security control is rated moderate if it can compromise data or functionality on the network equipment only if some other condition is met (e.g. a particular module or a user within a particular role is required). Moderate issue security bulletins typically include recommended actions to resolve the issue.

LOW

A security control is rated low if it is very difficult to exploit from outside or has a limited potential impact.

2.2 Deviations

Deviations to the measures must be corrected according to customer agreed Service Level Agreements (SLA). Atos will use default resolution targets for correcting the deviations that must be confirmed or changed by each customer.

Because correcting a deviation may impact the customer's business process, the analyst must decide whether or not the customer should be consulted. If the customer does not agree with correcting a deviation because doing so will negatively impact his business, a Risk Acceptance Form (RAF) has to be signed and handed over to formally transfer the associated risks to the customer. Atos will retain the right to accept or challenge the customer exception request.

3 Description of Measures

All measures in this document are categorized as MANDATORY. This categorization means that implementation is absolutely required. Exceptions to these measures must be registered in the Atos Risk Tool (ART) and approved by the CSM and Account Team.

The key words "MUST", "MUST NOT", "REQUIRED", "SHALL", "SHALL NOT", "SHOULD", "SHOULD NOT", "RECOMMENDED", "MAY", and "OPTIONAL" in this document are to be interpreted as described in RFC 2119 (<https://www.ietf.org/rfc/rfc2119.txt>).

All measures are grouped into specific areas. The specific areas are chosen to combine measures where the IT Security Control can be divided into multiple measures, e.g. "Updates and Patches", "User Management and Access Control" and "Protocols and Services".

The measures in this chapter will be tested by automated scan tooling.

3.1 Basic Security Rules

Measure ID	2WI00001
Measure Title	Remove all sample information
Classification	MODERATE
Baseline Reference	MSM-GSS-0005 – 2.1.13
Background	IIS provides sample documents, scripts and support documentation in its default configuration. They need to be removed to ensure that no identification of the kind of web server running can be shown.
Measure	Delete all sample documents and scripts or make sure they are not accessible from the web browser.
Implementation	Script will check for existence of AdminScripts, IISSamples, IISHelp, MSADC virtual directories.
Exception	
First appearance	19-05-2014

Measure ID	2WI00018
Measure Title	Supported Version
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	The IIS is based on the Microsoft Windows Operation system, if the operation system is not supported anymore the corresponding IIS is not supported.
Measure	Report the IIS version as outdated. Minimal Supported Version: IIS 8.0
Implementation	Script to check the version of IIS software.
Exception	
First appearance	09-04-2015

3.2 Configuration

Measure ID	2WI00003
Measure Title	Storage Location
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	The default storage location shouldn't be used and the storage location needs to be on a different drive than the system drive to avoid directory traversal attacks.
Measure	Store the web content in a dedicated NTFS disk volume that does not contain the operating system. Relocate the entire <i>inetpub</i> folder to another drive.
Implementation	Check each web root against: - NTFS file system - separate drive - Administrator and System groups with full access. Looking for all virtual directories and comparing its physical paths to system drive.
Exception	There might be virtual directories located on system drive, because of an application installation into the program files directory. These virtual directories can be ignored. C:\Program Files\... C:\Program Files (x86)\...
First appearance	19-05-2014

Measure ID	2WI00004
Measure Title	Web Application Pools
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	Separate web application pool should be used when dealing with completely different web applications, administration web sites or web applications accessed by different user groups. However, creating too many application pools may generate performance issues.
Measure	Define among the criteria detailed in the description which web sites should be in different web application pools and identify those which need the usage of .NET.
Implementation	Check all application pools against: - ApplicationPoolIdentity identity for those with built-in account selected Ensure if app pools identities are one of the following: ApplicationPoolIdentity(4) or specific user (3) or NetworkService(2), check that no LocalSystem (0) or LocalService (1) accounts are used.
Exception	
First appearance	19-05-2014

Measure ID	2WI00007
Measure Title	Configure unique binding

Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	By default, IIS listens to all the server interfaces and to all IP addresses. It needs to be restricted to ensure that only legitimate connections are processed.
Measure	Configure a unique binding for the protocols http, https and ftp only to the interfaces and IP addresses which it should listen to.
Implementation	Check http, https and ftp bindings against * (asterisk characters) and optionally blacklists. Check that IIS listens only on IP addresses and ports which it should listen to.
Exception	
First appearance	19-05-2014

3.3 Authentication and authorization

Measure ID	3WI00008
Measure Title	Anonymous Authentication
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Anonymous authentication should only be used for publicly available content
Measure	Enable anonymous authentication for unrestricted content on internet accessible web sites and unrestricted and restricted contents for intranet web sites. The other classified documents should be secured with an appropriate authentication method.
Implementation	Check all web sites against anonymous authentication enabled while user other than IUSR. Verify sites and its child items against anonymous authentication methods allowed, returns "non-compliant" if anonymous authentication is enabled and user identity is other than IUSR or other than application pool identity (for any of nodes (sites, applications))
Exception	
First appearance	19-05-2014

3.4 Transport Layer Security (TLS/SSL)

Measure ID	3WI00010
Measure Title	SSL cryptographic algorithm
Classification	CRITICAL
Baseline Reference	MSM-GSS-0005 – 2.1.12, 2.1.17
Background	SSL is outdated as a cryptographic layer and full vulnerable
Measure	Any SSL version has to be disabled
Implementation	Disable SSL 2.0 and SSL 3.0 protocol, if not deactivated by default Set DWORD values DisabledByDefault = 1 and Enabled = 0 on subkeys

	HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client Default values, if no key defined: <table><tr><th>IIS</th><th>SSL 2.0</th><th>SSL 3.0</th></tr><tr><td>8.x</td><td>deactivated</td><td>activated</td></tr><tr><td>10</td><td>deactivated</td><td>deactivated</td></tr></table> Check if TLS is enabled (see Measure ID 3WI00019).	IIS	SSL 2.0	SSL 3.0	8.x	deactivated	activated	10	deactivated	deactivated
IIS	SSL 2.0	SSL 3.0								
8.x	deactivated	activated								
10	deactivated	deactivated								
Exception										
First appearance	19-05-2014									

Measure ID	3WI00019
Measure Title	TLS cryptographic algorithm
Classification	CRITICAL
Baseline Reference	MSM-GSS-0005 – 2.1.12, 2.1.17
Background	TLS has to be enabled for secure connections
Measure	A list of trusted issuers is needed when client authentication is required. TLS 1.2 and TLS 1.3* must be enabled besides disabling TLS 1.0 and TLS 1.1. HTTPS is recommended for intranet and web-based applications and mandatory when classified information are hosted or WebDAV is used.
Implementation	Disable TLS 1.0 and TLS 1.1, if not deactivated by default. Enable TLS 1.2 and TLS 1.3*, if not activated by default. Set DWORD values DisabledByDefault = 1 and Enabled = 0 on subkeys HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Server HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Client Set DWORD values DisabledByDefault = 0 and Enabled = 0xffffffff on subkeys HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Server HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Client HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.3\Server HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.3\Client Recommended values:

	IIS	TLS 1.0**	TLS 1.1**	TLS 1.2	TLS 1.3*
	8.x	deactivated	deactivated	activated	activated*
	10	deactivated	deactivated	activated	Activated*
	** TLS 1.0 and 1.1 are outdated				
Exception					
First appearance	19-04-2015				

Measure ID	2WI00020																								
Measure Title	Disable weak ciphers																								
Classification	MODERATE																								
Baseline Reference	MSM-GSS-0005 - 2.1.12, 2.1.17																								
Background	TLS can use various cryptographic algorithms the appropriate algorithm and configuration has to be set to ensure a sufficient security for the transactions.																								
Measure	RSA/DSA certifications must have a length of at least 2048 bits, for ECDSA it has to be at least 224 bits. A list of trusted issuers is needed when client authentication is required. Weak ciphers need to be disabled, additional strong cipher suites must be enabled HTTPS is recommended for intranet and web-based applications and mandatory when classified information are hosted or WebDAV is used.																								
Implementation	Disable weak ciphers, if not deactivated by default In key <code>HKEY_Local_Machine\SystemnCurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\</code> create the subkeys 'DES 56/56', 'NULL', 'RC2 40/128', 'RC2 56/128', 'RC2 128/128', 'RC4 40/128', 'RC4 56/128', 'RC4 64/128', 'RC4 128/128', 'Triple DES 168' and set DWORD value Enabled = 0 Enable strong ciphers, if not activated by default In key <code>HKEY_Local_Machine\SystemnCurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\</code> create the subkeys 'AES 128/128', 'AES 256/256' and set DWORD value Enabled = 0xffffffff Default values, if no subkey defined: <table> <tr> <th>Cipher</th><th>IIS 8.x, 10</th></tr> <tr><td>DES 56/56</td><td>deactivated</td></tr> <tr><td>NULL</td><td>deactivated</td></tr> <tr><td>RC2 40/128</td><td>deactivated</td></tr> <tr><td>RC2 56/128</td><td>deactivated</td></tr> <tr><td>RC2 128/128</td><td>deactivated</td></tr> <tr><td>RC4 40/128</td><td>deactivated</td></tr> <tr><td>RC4 56/128</td><td>deactivated</td></tr> <tr><td>RC4 64/128</td><td>deactivated</td></tr> <tr><td>RC4 128/128</td><td>activated</td></tr> <tr><td>Triple DES 168</td><td>activated</td></tr> <tr><td>AES 128/128</td><td>activated</td></tr> </table>	Cipher	IIS 8.x, 10	DES 56/56	deactivated	NULL	deactivated	RC2 40/128	deactivated	RC2 56/128	deactivated	RC2 128/128	deactivated	RC4 40/128	deactivated	RC4 56/128	deactivated	RC4 64/128	deactivated	RC4 128/128	activated	Triple DES 168	activated	AES 128/128	activated
Cipher	IIS 8.x, 10																								
DES 56/56	deactivated																								
NULL	deactivated																								
RC2 40/128	deactivated																								
RC2 56/128	deactivated																								
RC2 128/128	deactivated																								
RC4 40/128	deactivated																								
RC4 56/128	deactivated																								
RC4 64/128	deactivated																								
RC4 128/128	activated																								
Triple DES 168	activated																								
AES 128/128	activated																								

	AES 256/256	activated	
Exception			
First appearance	09-04-2015		

Measure ID	2WI00021		
Measure Title	Disable weak hashing algorithms		
Classification	MODERATE		
Baseline Reference	MSM-GSS-0005 – 2.1.12, 2.1.17		
Background	TLS can use various cryptographic algorithms the appropriate algorithm and configuration has to be set to ensure a sufficient security for the transactions.		
Measure	RSA/DSA certifications must have a length of at least 2048 bits, for ECDSA it has to be at least 224 bits and 256 bits for SHA-2 (SHA-256) as recommended. A list of trusted issuers is needed when client authentication is required. Weak hashing algorithms needs to be disabled HTTPS is recommended for intranet and web-based applications and mandatory when classified information are hosted or WebDAV is used.		
Implementation	Disable weak hashing algorithms, if not deactivated by default In key HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\ create the subkey 'MD5' and 'SHA' or 'SHA256' and set DWORD value Enabled = 0		
	Default values, if no subkey defined:		
	Algorithm	IIS 8.x	IIS 10
	MD5*	activated	activated
	SHA-1*	activated	activated
	SHA-256 (SHA-2)	activated	activated
Exception	*MD5 and SHA-1 algorithms are known to have weaknesses and should only be used where required for compatibility purposes. If there is no compatibility problems with 3 rd party applications and browsers MD5 and SHA-1 should be deactivated.		
First appearance	07-02-2018		

Measure ID	3WI00022		
Measure Title	Enable HTTP Strict Transport Security (HSTS)		
Classification	CRITICAL		
Baseline Reference	MSM-GSS-0005 – 2.1.12		
Background	HSTS allows web servers to declare that web browsers (or other complying user agents) should only interact with it using secure HTTPS connections and never via the insecure HTTP protocol.		
Measure	Activate HSTS as custom HTTP header		
Implementation	Set custom HTTP Header in HTTP Response Headers with Name = <code>Strict-Transport-Security</code> Value = <code>max-age=63072000; includeSubDomains</code>		

	on server level
Exception	
First appearance	07-02-2018

Measure ID	2WI00028
Measure Title	KeyExchangeAlgorithm
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	Specify the Diffie-Helman key bit length for the TLS server to a minimum key size.
Measure	Configure the modulus size of Diffie-Hellman Ephemeral (DHE) to 2048 bit
Implementation	In key HKEY_Local_Machine\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\KeyExchangeAlgorithms\ create the subkey 'Diffie-Hellman' (if it didn't exist already). Inside that create a new DWORD called "ServerMinKeyBitLength"=2048 or 00000800(in hex)
Exception	
First appearance	22-01-2020

3.5 Modules and features

Measure ID	2WI00011
Measure Title	WebDAV configuration
Classification	MODERATE
Baseline Reference	MSM-GSS-0002 –2.1.4
Background	Activate WebDAV only where it is needed especially if the web site is internet facing.
Measure	Allow WebDAV access to specified content only if applicable. Do not allow more than read-only permissions for "All Users" or Anonymous. Write or Source permission should be granted only to authenticated users. Ensure that NTFS permissions are aligned to the permissions defined for WebDAV.
Implementation	For WebDAV enabled directories: - Allow "Read-only" access for "All users" or anonymous only; As soon as "Write" or "Source" permissions are granted, access has only to be possible to authenticated users. - Never grant execute NTFS permissions ("Script only" or "Script and Executables") to areas with "Write" access. This would allow an attacker to upload and run scripts. - Deny "Write" access to the anonymous IIS user - Use WebDAV only in combination with TLS/SSL
Exception	
First appearance	19-05-2014

Measure ID	2WI00012
Measure Title	FTP Configuration
Classification	MODERATE
Baseline Reference	MSM-GSS-0005 – 2.1.16
Background	FTP is an insecure protocol. All data, including user and password information, is transferred in clear text.
Measure	Never grant anonymous user read and write access on the same folder, prefer the usage of an upload directory. NTFS quotas should be set for the upload directory. Classified data or authentication credentials must not be transferred via FTP. Use FTP over SSL instead to encrypt both FTP channels (ports 20 and 21). Implement logon attempt restrictions when authentication is active. Configure unique binding. Enable ftp application logging.
Implementation	- If using the plain old FTP protocol, use anonymous authentication as the only "real" authentication mechanism, otherwise use FTP over SSL with basic authentication. - Never grant anonymous users Read and Write access simultaneously on the same root folder. Implement with FTP Authorization Rules. - Enable logon attempt restrictions for IIS 8 and higher with parameters Maximum number of failed logon attempts = 10 Time period (in seconds) = 90 Deny IP addresses based on the numbers of failed login attempts - Configure unique binding (see WI00007)

	- Enable FTP logging
Exception	
First appearance	19-05-2014

Measure ID	3WI00013
Measure Title	Directory Browsing
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Activated directory browsing creates a risk to display the files available on the server as well as the directory structure
Measure	Directory browsing has to be disabled unless a specific reason obliges to activate it on a particular directory
Implementation	Check if the directory browsing on the server/web site/directory level is disabled
Exception	
First appearance	19-05-2014

Measure ID	2WI00014
Measure Title	Error Messages
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	Default error messages are too detailed and provide a mean for a potential attacker to discover many information on the server and the application.
Measure	Configure IIS to return only simple messages for remote users
Implementation	Error Responses of Error Pages must not "Detailed Errors" (ErrorMode = Detailed)
Exception	
First appearance	19-05-2014

3.6 Additional Security measures

Measure ID	2WI00015
Measure Title	.NET Trust level
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	ASP.NET trust level is set to full by default, restricting this access allows to set the limits in which the code can act.
Measure	Set the ASP.NET trust level to medium
Implementation	Check ASP.NET trust level to be set to medium
Exception	IIS for SharePoint services
First appearance	19-05-2014

Measure ID	2WI00024
Measure Title	MIME-Handling Security
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	Content sniffing can expose the web site/app to attacks based on MIME-type confusion which can lead to security problems.
Measure	Browsers provide a way to opt-out of MIME sniffing by using the X-Content-Type-Options: nosniff HTTP response header
Implementation	Set custom HTTP Header in HTTP Response Headers with Name = X-Content-Type-Options Value = nosniff on server level
Exception	
First appearance	07-02-2018

Measure ID	2WI00025
Measure Title	Content-Security-Policy
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	Cross-site scripting (XSS) attacks are a common threat for web services
Measure	The Content-Security-Policy HTTP response header helps you reduce XSS risks on modern browsers by declaring what dynamic resources are allowed to load via a HTTP Header.
Implementation	Set custom HTTP Header in HTTP Response Headers with Name = Content-Security-Policy Value = default-src 'self'; on server level
Exception	IIS for SharePoint services
First appearance	07-02-2018

Measure ID	2WI00026
Measure Title	X-Frame-Options
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	Protection of web applications against clickjacking
Measure	Setting the X-Frame-Options HTTP header can tell browsers if iframe, frame or object HTML embedding is allowed for the served content and for which origin resource. Set most conservative value.
Implementation	Set custom HTTP Header in HTTP Response Headers with Name = X-Frame-Options Value = SAMEORIGIN on server level
Exception	IIS for SharePoint services
First appearance	07-02-2018

Measure ID	2WI00027
Measure Title	X-XSS-Protection
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	Cross-site scripting (XSS) attacks are a common threat for web services
Measure	Setting the X-XSS-Protection HTTP header will enable the XSS protection and instruct the browser to block the response in the event that a malicious script has been inserted from user input, instead of sanitizing.
Implementation	Set custom HTTP Header in HTTP Response Headers with Name = X-XSS-Protection Value = 1; mode=block on server level
Exception	
First appearance	07-02-2018

3.7 Secure Administration

Measure ID	2WI00016
Measure Title	IIS configuration auditing
Classification	MODERATE
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	IIS provides auditing capabilities to track every change made to the configuration.
Measure	Enable "IIS Configuration Auditing". Ensure that all relevant information is logged by the web server. Configure log rotation mechanism.
Implementation	- Enable Microsoft-IIS-Configuration/Administrative and Microsoft-IIS-Configuration/Operational logging. - Limit log size to 36032 KB Set settings with Event Viewer or programmatically.
Exception	
First appearance	19-05-2014

Measure ID	2WI00017
Measure Title	NTFS Auditing Settings
Classification	MODERATE
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	NTFS provides auditing capabilities to track every access made to the filesystem.
Measure	Configure NTFS auditing for the web content folder.
Implementation	Enable NTFS auditing to the web root folder for Everyone with settings - on Failed Events with inheritable basic permission "Full Control" - on All Events with inheritable advanced permissions "Create files / write data; Create folders / append data; Delete subfolders and files; Delete; Change Permissions; Take ownership"
Exception	
First appearance	09-05-2015

Measure ID	3WI00023
Measure Title	IIS logging
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	IIS logs provide valuable information that can be used to identify any unauthorized attempts to compromise the Web server.
Measure	Enable IIS logging in W3C format, select all fields on site level and schedule logfile rollover. Ensure storing of logs in a secured location with access rights only for authorized persons and systems. Remove all logs which exceeding retention time of the national law.
Implementation	Enable IIS logging on webserver level in W3C format with the fields "Date, Time, ClientIP, UserName, SiteName, ComputerName, ServerIP, Method, UriStem, UriQuery, HttpStatus, Win32Status, BytesSent, BytesRecv, TimeTaken, ServerPort, UserAgent, Cookie, Referer, ProtocolVersion, Host, HttpSubStatus". All sites will inherit these settings. Store logs on a NTFS secured folder with no access to Everyone or Users. By default, IIS logs are stored in a folder with access only to Administrators and System. Use adequate procedure to delete unnecessary logs.
Exception	
First appearance	07-02-2018

4 Non-Alcatraz measures

These settings will be not be regularly scanned, instead those settings needs to be manually checked after initial installation.

4.1 Webserver related measures

The following measures cannot be tested by automated tooling but are necessary to be implemented for the systems in scope.

Measure ID	2WI00002
Measure Title	IIS Module activation
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	Many modules can be installed with IIS and not all of them are useful for a given usage, activating only needed component limiting the attack surface.
Measure	Verify the list of components needed by the application to perform the expected service.
Implementation	Verify IIS Modules
Exception	
First appearance	19-05-2014

Measure ID	1WI00005
Measure Title	Web Service Extensions
Classification	LOW
Baseline Reference	No reference to Security Baseline
Background	Activation of unnecessary web service extension increases the security risk for the web server. Only needed web service extension should be activated.
Measure	Activate only the web service extension which requires to be activated and disable to others.
Implementation	Verify Web Service Extensions
Exception	
First appearance	19-05-2014

Measure ID	1WI00006
Measure Title	Request Handler Mapping
Classification	LOW
Baseline Reference	No reference to Security Baseline
Background	Unnecessary request handlers should be disabled to reduce the security risk of using an exploit associated to the handlers
Measure	Do not add or enable any handler mapping that are not needed by the application or IIS itself.
Implementation	Verify Request Handler Mappings
Exception	

First appearance	19-05-2014
------------------	------------

Measure ID	3WI00009		
Measure Title	NTFS File system permissions		
Classification	CRITICAL		
Baseline Reference	MSM-GSS-0002 – 2.1.1, 2.1.4		
Background	Set the permissions to access the web sites resources to be as restrictive as possible.		
Measure	All local user and groups permissions need to be removed unless specifically needed by the application. Set the permission read only by default to the anonymous authentication user. Make sure that no executables from the operating system can be accessed.		
Implementation	Set the NTFS permissions in the security properties of the folder to be as restrictive as possible and only allow execution rights to the needed executable files.		
	Folder type	Share permissions	NTFS permissions
	Public folder. A folder that can be accessed by everyone.	Grant Change permission to the Users group.	Grant Modify permission to the Users group.
	Drop folder. A folder where users can drop confidential data.	Grant Change permission to the Users group. Grant Full Control permission to the group manager.	Grant Write permission for the Users group that is applied to This Folder only . Grant Full Control permission to the group manager.
	Application folder. A folder containing applications that can be run over the network.	Grant Read permission to the Users group.	Grant Read, Read & Execute, and List Folder Contents permissions to the Users group.
	Home folder. An individual folder for each user. Only the user has access to the folder.	Grant Full Control permission to each user on his or her respective folder.	Grant Full Control permission to each user on his or her respective folder.
Exception			
First appearance	19-05-2014		

Appendix 1 Checklist

Device Name			
Measure ID	Measure title	Alcatraz	Checked
2WI00001	Remove all sample information	YES	
2WI00002	IIS Module activation	NO	
2WI00003	Storage Location	YES	
2WI00004	Web Application Pools	YES	
1WI00005	Web Service Extensions	NO	
1WI00006	Request Handler Mapping	NO	
2WI00007	Configure unique binding	YES	
3WI00008	Anonymous Authentication	YES	
3WI00009	NTFS File system permissions	NO	
3WI00010	SSL cryptographic algorithm	YES	
2WI00011	Webdav configuration	YES	
2WI00012	FTP Configuration	YES	
3WI00013	Directory Browsing	YES	
2WI00014	Error Messages	YES	
2WI00015	.NET Trust level	YES	
2WI00016	IIS configuration auditing	YES	
2WI00017	NTFS Auditing Settings	YES	
2WI00018	Supported Version	YES	
3WI00019	TLS cryptographic algorithm	YES	
2WI00020	Disable weak ciphers	YES	
2WI00021	Disable weak hashing algorithms	YES	
3WI00022	Enable HTTP Strict Transport Security (HSTS)	YES	
3WI00023	IIS logging	YES	
2WI00024	MIME-Handling Security	YES	
2WI00025	Content-Security-Policy	YES	
2WI00026	X-Frame-Options	YES	
2WI00027	X-XSS-Protection	YES	
2WI00028	KeyExchangeAlgorithm	YES	